

Governança integrada habilita consulta em linguagem natural sobre ocupação de leitos hospitalares

Gabriel Arcenio Rahal Marostica

Orientador: José Bernardo Neto

MBA em Engenharia de Software — USP/Esalq, 2026

Resumo

Este trabalho propõe e implementa uma arquitetura de referência para Conversational Analytics em ambiente hospitalar, com governança integrada e aderente à LGPD, às normas da ANVISA e às diretrizes da ANPD, aplicada ao domínio de ocupação de leitos. O protótipo organiza um pipeline de dados em camadas (Bronze, Silver e Gold) sob um motor de tradução de perguntas em linguagem natural para SQL, com controles de governança na entrada e na saída e avaliação por execution match. Toda a pesquisa usa dados exclusivamente sintéticos, com pipeline de dados determinista. Os resultados preliminares confirmam a anonimização da camada exposta ao modelo e o funcionamento dos controles de governança. Numa avaliação com 18 perguntas (modelo claude-sonnet-4-6, temperatura zero, três execuções sem variação), o execution match estrito foi de 61,1%, enquanto o set match de conteúdo, métrica diagnóstica que ignora forma e bloqueios de governança, foi de 94,4%, indicando que a maior parte das divergências decorre da forma do resultado e do controle de acesso, e não de erro de cálculo do modelo (apenas 1 das 18). Dado o tamanho da amostra, os números são indicativos e reportados com intervalo de confiança; a investigação central não é atingir um limiar fixo de acurácia, mas caracterizar o equilíbrio entre utilidade e governança.

Palavras-chave: Text-to-SQL; conformidade regulatória; dados sintéticos; saúde digital; execution match.

1. Introdução

As interfaces em linguagem natural para bancos de dados são um campo de pesquisa maduro (AFFOLTER; STOCKINGER; BERNSTEIN, 2019). Em particular, a tradução de perguntas em linguagem natural para consultas SQL (Text-to-SQL) é objeto de estudo consolidado, com benchmarks de referência como o Spider (YU et al., 2018) e, no domínio clínico, o EHRSQL (LEE et al., 2022), e tem sido profundamente transformada pelos modelos de linguagem de grande porte (SHI et al., 2024). A

adoção desses modelos para consulta a dados clínicos em linguagem natural promete ampliar o acesso de gestores e equipes assistenciais à informação, mas esbarra em um obstáculo central: a governança dos dados e do próprio modelo costuma ser tratada de forma fragmentada, separada da arquitetura de dados. Em saúde, essa fragmentação é crítica, pois envolve dados pessoais sensíveis e um marco regulatório exigente, composto pela Lei Geral de Proteção de Dados (BRASIL, 2018), pelas normas da ANVISA aplicáveis a software como dispositivo médico (ANVISA, 2022) e pelas diretrizes da Autoridade Nacional de Proteção de Dados (ANPD, 2024). Soma-se a isso a necessidade de controlar riscos específicos dos modelos de linguagem, como a injeção de comandos e o acesso indevido a recursos (OWASP, 2023), tratados na prática por meio de guardrails programáveis (REBEDEA et al., 2023) e, no setor de saúde, sob diretrizes éticas e de governança dedicadas (WHO, 2024).

Este trabalho parte da hipótese de que é possível integrar a governança à arquitetura de dados, de ponta a ponta, preservando a utilidade da consulta em linguagem natural dentro do escopo autorizado a cada perfil, a um custo mensurável e justificável pelo princípio do menor privilégio. Propõe-se uma arquitetura de referência em quatro camadas, na qual a anonimização, o controle de acesso por perfil, a validação da consulta e a auditoria atravessam todo o fluxo, da pergunta do usuário à resposta entregue. O domínio escolhido para implementação e avaliação é a ocupação de leitos hospitalares, e toda a pesquisa utiliza dados exclusivamente sintéticos, o que elimina na origem o risco de exposição de dados reais e permite que a arquitetura seja replicada por outras instituições.

O objetivo geral é demonstrar, por meio de um protótipo funcional, a viabilidade dessa arquitetura integrada e caracterizar o equilíbrio entre a utilidade da consulta (medida por execution match sobre dados sintéticos) e os controles de governança. A pergunta de pesquisa que orienta o trabalho é: uma arquitetura que integra a governança de ponta a ponta preserva a utilidade da consulta em linguagem natural, e a que custo mensurável? Em vez de fixar um limiar arbitrário de acurácia, o trabalho busca medir o desempenho observado, com seus intervalos de confiança, e analisar a natureza dos erros. Como objetivos específicos, o trabalho se propõe a: (a) revisar a literatura sobre Conversational Analytics, Text-to-SQL e governança de modelos de linguagem; (b) mapear os requisitos regulatórios aplicáveis (LGPD, ANVISA e ANPD); (c) projetar a arquitetura técnica, da ingestão ao Lakehouse e ao motor com guardrails; (d)

desenvolver o modelo de governança, contemplando controle de acesso, rastreabilidade, anonimização e validação; e (e) implementar e avaliar o protótipo sobre dados sintéticos.

2. Metodologia

A pesquisa caracteriza-se como um estudo de caso instrumental apoiado no desenvolvimento de um protótipo. Os métodos são descritos a seguir na mesma ordem em que os resultados são apresentados.

2.1 Geração do dataset sintético

Os dados foram gerados de forma determinista e materializados na camada Bronze do pipeline. A geração emprega a biblioteca Faker com localidade pt_BR, governada por uma semente única, e ancora-se em uma data de referência fixa da simulação. O ambiente representa um hospital de grande porte, com oito unidades, duzentos leitos e seiscentos pacientes, e abrange uma janela histórica de noventa dias de ocupação diária. Dados pessoais identificáveis (nome, CPF e data de nascimento) são inseridos de propósito na Bronze, para que a anonimização realizada na camada seguinte seja real e demonstrável.

2.2 Arquitetura em quatro camadas

A arquitetura organiza o sistema em quatro camadas encadeadas: o pipeline Lakehouse (Bronze, Silver e Gold), a governança de entrada, o motor de tradução de perguntas em SQL e a validação de saída. O pipeline foi implementado em DuckDB. A camada Bronze recebe os dados brutos; a Silver limpa e anonimiza; e a Gold expõe métricas agregadas, sendo a única camada visível ao motor de linguagem. As camadas internas, Bronze e Silver, permanecem inacessíveis ao modelo.

2.3 Modelo de governança

A governança foi concebida como defesa em profundidade, alinhada às boas práticas de gestão de risco de sistemas de inteligência artificial (NIST, 2023). Na entrada, seis guardrails verificam que a consulta candidata é uma única instrução somente leitura, sem comandos de escrita ou administrativos, restrita às tabelas Gold autorizadas ao perfil do usuário, e a execução ocorre sobre uma conexão de banco somente leitura. Na saída, a validação confere o aterramento da consulta contra o schema Gold conhecido, bloqueia qualquer coluna de resultado cujo nome corresponda a um campo sensível e registra cada pergunta e cada resposta em uma trilha de auditoria,

com o evento da interação. Os guardrails endereçam, no contexto de Text-to-SQL, riscos catalogados para aplicações de modelos de linguagem, como a injeção de comandos e o acesso indevido a recursos (OWASP, 2023), na linha de abordagens de guardrails programáveis (REBEDEA et al., 2023).

2.4 Conformidade regulatória

Os requisitos regulatórios foram mapeados a controles concretos da arquitetura, à camada responsável e à sua situação de implementação. O mapeamento cobre a LGPD, as normas da ANVISA aplicáveis a software como dispositivo médico e as diretrizes da ANPD, totalizando onze requisitos, e evidencia que a governança atravessa as quatro camadas e não se restringe ao motor de inteligência artificial.

Cabe um esclarecimento de enquadramento. O protótipo realiza analytics de ocupação de leitos para apoio à gestão hospitalar, sem finalidade diagnóstica ou terapêutica sobre paciente individual; nesse escopo, não se caracteriza como software como dispositivo médico (SaMD) sob a RDC 657/2022. As normas da ANVISA são, portanto, adotadas por analogia, como referência de boas práticas de controle, segurança e rastreabilidade de software em saúde, e não como obrigação de regularização de dispositivo médico. Uma eventual evolução do sistema para finalidade clínica individual exigiria reavaliar esse enquadramento.

2.5 Método de avaliação

A avaliação adota a métrica de execution match, consolidada em benchmarks de Text-to-SQL como o Spider (YU et al., 2018), o EHRSQL (LEE et al., 2022) e o BIRD (LI et al., 2023): a consulta gerada pelo modelo e a consulta de referência são executadas e seus conjuntos de resultados são comparados após normalização (arredondamento numérico com tolerância de duas casas, datas em formato ISO e linhas ordenadas). Além da acurácia, são medidos dois indicadores de governança: a taxa de aprovação das consultas pelos guardrails e a completude do log de auditoria. O conjunto de avaliação reúne dezoito perguntas em português, com a respectiva consulta de referência sobre a Gold, cobrindo quatro tipos de pergunta operacional: status atual, métrica por unidade, série histórica e interações por faixa etária. O motor existe em duas implementações intercambiáveis: o oráculo, que devolve a consulta de referência e serve apenas para autoteste do pipeline, e o modelo de linguagem real, que gera os números reportados. Por simplicidade de redação, o termo acurácia é

usado como sinônimo de execution match (taxa de correspondência exata de conjuntos de resultados), e não no sentido de acurácia de classificação.

Além do execution match estrito, adota-se uma métrica secundária diagnóstica: o set match de conteúdo, que verifica se todos os valores do resultado de referência aparecem no resultado gerado, ignorando colunas extras, ordem e bloqueios de governança. Ela serve apenas para separar, na análise de erros, o conteúdo correto de divergências de forma ou de controle de acesso. Trata-se de um teste de contenção (recall): por construção, é permissivo, pois uma consulta excessivamente ampla poderia conter os valores de referência e ainda assim estar errada por excesso; portanto, deve ser lido como um teto (limite superior), não como piso. O execution match estrito permanece como métrica primária e não é substituído por ela; essa escolha preserva a comparabilidade com a literatura (Spider, EHRSQL, BIRD), ainda que a pergunta de pesquisa seja melhor respondida pela decomposição entre conteúdo correto e custo da governança. As proporções, dado o tamanho do conjunto, são acompanhadas de intervalo de confiança de 95% (método de Wilson). A chamada ao modelo usa temperatura zero, e a avaliação é repetida em três execuções, com o modelo, a temperatura, o número de execuções e a estabilidade por pergunta registrados no relatório.

2.6 Reprodutibilidade e integridade

A reprodutibilidade do pipeline e dos dados foi assegurada por construção. Uma semente fixa e uma data de referência fixa controlam toda a geração de dados e as consultas que mencionam datas relativas; o ambiente foi fixado em uma versão específica de Python, com dependências travadas por versão e uma imagem reprodutível cuja base é fixada por digest. A integração contínua executa, a cada alteração, apenas o motor oráculo, sem chave de API e sem custo. Há, porém, um limite honesto a registrar: o número de acurácia provém de uma chamada a um modelo de linguagem externo, que não é estritamente reproduzível como o restante do pipeline e é justamente o único resultado que a integração contínua não reexecuta. Ele é, portanto, reportado como observação empírica, com modelo (claude-sonnet-4-6), temperatura (zero), número de execuções (três) e data fixados e registrados, e acompanhado da estabilidade por pergunta entre as execuções. Como princípio de integridade, os números de acurácia provêm somente da execução real do modelo, nunca do oráculo, que serve apenas de autoteste do pipeline.

3. Resultados Preliminares

Apresentam-se a seguir os resultados parciais verificáveis. Os números do pipeline e dos dados provêm de execução determinista e são reprodutíveis; os números do modelo (subseção 3.5) são observação pontual, conforme a ressalva da subseção 2.6.

3.1 Geração do dataset sintético

A geração produziu, de forma determinista, oito unidades, duzentos leitos, seiscentos pacientes, 2.012 internações e 18.000 registros de ocupação diária. No dia de referência (31 de maio de 2026), o hospital apresentava 150 leitos ocupados, 42 livres e 8 bloqueados, o que corresponde a uma taxa de ocupação de 75,0%. A coerência foi verificada: as 150 internações ativas igualaram exatamente os 150 leitos ocupados no dia de referência. A transformação para as camadas Silver e Gold confirmou a anonimização: a tabela de pacientes da Silver não contém nome, CPF nem data de nascimento; o identificador do paciente foi substituído por um pseudônimo derivado de hash com salt, sem colisão entre os seiscentos pacientes; e a data de nascimento deu lugar à faixa etária, em linha com os princípios de anonimização e generalização de atributos identificadores (SWEENEY, 2002). A Tabela 1 resume o snapshot de ocupação por unidade.

Unidade	Total	Ocup.	Livres	Bloq.	Taxa (%)
Cardiologia	25	18	6	1	72,0
Pediatria	25	17	6	2	68,0
Clínica Médica	25	21	4	0	84,0
Cirurgia Geral	25	23	2	0	92,0
Ortopedia	25	16	5	4	64,0
Neurologia	25	20	5	0	80,0
Oncologia	25	17	7	1	68,0
Pronto-Socorro	25	18	7	0	72,0
Hospital	200	150	42	8	75,0

Tabela 1. Ocupação por unidade no dia de referência (camada Gold). Fonte: o autor.

3.2 Arquitetura de referência em quatro camadas

A arquitetura foi documentada e implementada nas quatro camadas, com fluxo rastreável da pergunta do usuário à resposta entregue. Apenas a camada Gold, agregada, é exposta ao modelo; as camadas Bronze e Silver permanecem

inacessíveis. A documentação modular do protótipo consolida essa arquitetura como o principal artefato de referência do trabalho, com decisões, regras críticas, controles e requisitos regulatórios identificados e rastreáveis ao código. A numeração das camadas (1 a 4) é lógica e arquitetural; a ordem de execução em tempo de consulta é outra, partindo da governança de entrada (2) para o motor (3), o pipeline de dados (1) e a validação de saída (4), como ilustra a Figura A.1.

3.3 Modelo de governança de entrada e saída

Os controles de governança foram implementados e verificados por testes. A eficácia foi observada na avaliação com o modelo real: em duas perguntas (Q01 e Q11), o modelo produziu uma consulta que retornaria o número correto, porém a partir de uma tabela fora do escopo autorizado ao perfil de enfermagem. Em ambos os casos, o guardrail de escopo por perfil bloqueou a execução antes que a consulta tocasse o banco, evidenciando que o controle de acesso por finalidade opera como projetado. A validação de saída e a auditoria da resposta completam a barreira final de governança.

Esse comportamento revela um achado quantificável: existe um trade-off explícito entre a acurácia medida e a governança. As duas perguntas bloqueadas tinham conteúdo correto, mas foram barradas por acessarem tabela fora do escopo do perfil; ou seja, o controle de acesso por finalidade custou 2 das 18 perguntas, cerca de 11 pontos percentuais de execution match. Trata-se de um custo deliberado e desejável: a arquitetura prefere recusar uma resposta correta obtida por um caminho não autorizado a entregá-la violando o princípio do menor privilégio. Quantificar esse custo é, em si, um resultado: responde com dados à pergunta sobre se a governança compromete a utilidade.

3.4 Conformidade regulatória

O mapeamento entre os onze requisitos regulatórios e os controles da arquitetura foi concluído, associando cada requisito a um controle implementado, à camada responsável e à sua situação. O resultado demonstra que a governança é transversal às quatro camadas, e não um componente isolado do motor de inteligência artificial.

3.5 Avaliação

O pipeline de avaliação foi exercitado de ponta a ponta com o motor oráculo. Para as dezoito perguntas, o execution match resultou em 100%, a aprovação na governança

em 100% e a completude do log em 100%. Esse resultado é um autoteste do pipeline e não representa o desempenho do modelo.

A execução com o modelo de linguagem real (claude-sonnet-4-6, temperatura zero) foi repetida três vezes sobre as dezoito perguntas. O resultado foi idêntico nas três execuções (desvio nulo): 61,1% de execution match estrito (11 de 18) e 94,4% de set match de conteúdo (17 de 18). A estabilidade por pergunta foi total: cada pergunta acertou ou errou nas três execuções (0/3 ou 3/3), sem casos intermediários; em particular, o único erro de conteúdo (Q12) repetiu-se nas três, sendo portanto sistemático, e não fruto da variância de uma rodada. Ainda assim, o desvio nulo não elimina a incerteza estatística do tamanho da amostra: com 18 perguntas, os intervalos de confiança de 95% (Wilson) são amplos, [38,6%; 79,7%] para o execution match estrito e [74,2%; 99,0%] para o set match de conteúdo. Uma execução-piloto anterior, sobre um subconjunto de dez dessas perguntas, havia dado 60,0%. O patamar do execution match estrito é coerente com a literatura, em que mesmo modelos avançados alcançam acurácia limitada em benchmarks realistas, a exemplo dos cerca de 40% relatados para o ChatGPT no BIRD (LI et al., 2023). A Tabela 2 resume os indicadores.

Indicador	Valor	IC 95% (Wilson)
Execution match estrito (primária)	61,1% (11/18)	[38,6%; 79,7%]
Set match de conteúdo (secundária, diagnóstica)	94,4% (17/18)	[74,2%; 99,0%]
Aprovação na governança *	88,9% (16/18)	—
Completude do log de auditoria	100% (18/18)	—

Tabela 2. Indicadores de avaliação do modelo real (claude-sonnet-4-6, temperatura zero, média de três execuções com desvio nulo) sobre 18 perguntas. Execution match estrito = AVAL-001 (primária); aprovação na governança = AVAL-002; completude do log = AVAL-003; set match de conteúdo = métrica secundária diagnóstica. () As 2 consultas não aprovadas são recusas corretas por menor privilégio (Q01 e Q11), comportamento esperado, e não falhas. IC pelo método de Wilson. Fonte: o autor.*

A distância entre o execution match estrito (61,1%) e o set match de conteúdo (94,4%) é o resultado mais informativo: os 33 pontos de diferença não vêm de raciocínio errado, mas da forma do resultado e da governança. A Tabela 3 decompõe os dezoito casos. O conteúdo esteve correto em 17 deles; apenas um (Q12) apresentou erro de conteúdo. Esse único erro não é bem uma falha de raciocínio do modelo, mas uma lacuna de desenho do nosso pipeline: o prompt não expõe ao modelo os valores categóricos do schema, e ele filtrou um valor com a caixa incorreta ("enfermaria" em

vez de "Enfermaria"), obtendo conjunto vazio. Esse ponto (value linking) já está no plano de continuidade. Manteve-se o execution match estrito como métrica primária; o set match de conteúdo é diagnóstico e acompanha a análise, sem substituí-la.

Vale uma leitura do ponto de vista do usuário final. Um gestor recebe um número, não a SQL; para ele, as divergências de forma e projeção (colunas adicionais) tendem a não reduzir a utilidade percebida, ainda mais porque o filtro de saída já barra colunas sensíveis. Sob essa ótica, a utilidade operativa da resposta aproxima-se dos 94,4% do conteúdo correto, e os 61,1% do execution match estrito penalizam artefatos de forma que não enganam o usuário. Isso não rebaixa a métrica primária, mantida por comparabilidade, mas reforça a tese de utilidade preservada dentro do escopo autorizado.

Categoria	Itens	Natureza
Correta (execution match estrito)	11	Conjunto de resultados idêntico ao da referência.
Conteúdo certo, forma/projeção	4	Valores corretos, com colunas extras ou formato distinto; limitação do execution match (Q04, Q13, Q14, Q15).
Conteúdo certo, bloqueio de governança	2	Valor correto, mas via tabela fora do escopo do perfil; barrado pelo guardrail (Q01, Q11).
Erro de conteúdo	1	Filtragem de valor categórico com caixa incorreta; lacuna de value linking no prompt (Q12).

Tabela 3. Categorização dos dezoito casos da execução com o modelo real. Conteúdo correto em 17 de 18 (94,4%); execution match estrito em 11 de 18 (61,1%). Fonte: o autor.

A estratificação por tipo de pergunta (Tabela 4) revela que as causas das divergências não se distribuem por igual. As interações por faixa etária tiveram execution match estrito perfeito (4 de 4). As divergências de forma e projeção concentraram-se nas métricas por unidade (3 dos 4 casos), em que o modelo tende a projetar colunas adicionais; já os bloqueios de governança e o único erro de conteúdo recaíram todos sobre o status atual de leitos, em consultas do perfil de enfermagem. Em outras palavras, o teto do execution match estrito é puxado por motivos diferentes em cada tipo, o que orienta o trabalho de continuidade.

Tipo de pergunta	Estrito	Conteúdo	Natureza das divergências
Status atual (5)	2/5	4/5	2 bloqueios de governança (Q01, Q11) e

			1 erro de conteúdo (Q12).
Métrica por unidade (5)	2/5	5/5	3 divergências de forma/projeção (Q04, Q13, Q14).
Série histórica (4)	3/4	4/4	1 divergência de forma (Q15).
Faixa etária (4)	4/4	4/4	Sem divergências.

Tabela 4. Execution match estrito e set match de conteúdo por tipo de pergunta. Fonte: o autor.

3.6 Reprodutibilidade e integridade

A reprodutibilidade do pipeline foi confirmada: a mesma configuração reproduz os mesmos dados e números, inclusive entre as versões 3.12 e 3.14 do Python. A integração contínua executa o autoteste a cada alteração, sem chave e sem custo, e a imagem reprodutível fixa o ambiente por completo. O número de acurácia, por vir de um modelo externo, é a exceção: foi coletado em três execuções reais (resultado idêntico nas três, desvio nulo), com modelo, temperatura e data registrados, e é reportado como observação empírica com intervalo de confiança (subseção 2.6). A metodologia de medição foi decidida antes da reexecução, e o execution match estrito (primária) é reportado junto da métrica secundária de conteúdo, sem que esta o substitua, preservando a integridade dos resultados.

4. Ameaças à validade

Os resultados preliminares devem ser lidos à luz de algumas ameaças à validade, registradas aqui de forma explícita. Quanto à validade externa, os dados são inteiramente sintéticos e o estudo cobre um único domínio (ocupação de leitos): os números não devem ser generalizados para dados clínicos reais ou para outros domínios sem nova avaliação. Quanto à validade de conclusão estatística, o conjunto tem apenas 18 perguntas, o que produz intervalos de confiança amplos; as três execuções com desvio nulo reduzem a dúvida sobre a variância de rodada, mas não estreitam esses intervalos, e não cobrem a variação entre diferentes modelos ou versões, já que se avaliou um único modelo de linguagem.

A ameaça mais relevante é de validade de construção: o mesmo autor elaborou as perguntas, as consultas de referência (gold) e o próprio sistema. Há, portanto, o risco de o conjunto de avaliação ter sido, ainda que sem intenção, moldado àquilo que o sistema já faz bem, o que tende a inflar as métricas. Mitiga-se isso parcialmente com a transparência do conjunto e da análise de erros, mas a construção de um conjunto

por terceiros, ou a partir de demandas reais de gestores, fica como trabalho necessário. Some-se a isso que a métrica secundária de conteúdo é um teste de contenção (recall) e, por ser permissiva por construção, deve ser interpretada como teto, não como piso. Antecipar essas limitações faz parte da leitura honesta dos resultados, e não as anula.

5. Considerações Finais (parciais)

Os resultados preliminares confirmam a viabilidade técnica da arquitetura integrada: o pipeline de dados é coerente e anonimizado, os controles de governança funcionam de ponta a ponta e a avaliação produz números reais e verificáveis. Quanto à pergunta de pesquisa, os dados sugerem que a governança integrada preserva a utilidade da consulta dentro do escopo autorizado, a um custo mensurável e justificável pelo menor privilégio: o conteúdo das respostas esteve correto em 17 de 18 casos (94,4%), enquanto o execution match estrito (61,1%) é puxado para baixo pela forma do resultado e pelo controle de acesso, não pelo raciocínio do modelo; o custo direto da governança foi de cerca de 11 pontos (2 respostas corretas, mas fora do escopo do perfil). Esses números, porém, vêm de uma amostra pequena, com intervalos de confiança amplos, e devem ser lidos como indicativos. Como continuidade, preveem-se o tratamento de value linking (exposição dos valores categóricos do schema ao modelo), a ampliação e estratificação do conjunto de avaliação por tipo de pergunta e por perfil (para estreitar os intervalos) e o aprofundamento da discussão sobre a métrica sensível à forma.

Referências

- AFFOLTER, K.; STOCKINGER, K.; BERNSTEIN, A. A comparative survey of recent natural language interfaces for databases. *The VLDB Journal*, v. 28, n. 5, p. 793-819, 2019. DOI: 10.1007/s00778-019-00567-8. Disponível em: <https://doi.org/10.1007/s00778-019-00567-8>. Acesso em: 10 jun. 2026.
- AGÊNCIA NACIONAL DE VIGILÂNCIA SANITÁRIA (ANVISA). Resolução da Diretoria Colegiada – RDC nº 657, de 24 de março de 2022. Dispõe sobre a regularização de software como dispositivo médico (Software as a Medical Device – SaMD). Brasília, DF: Anvisa, 2022. Disponível em: <https://anvisalegis.datalegis.net/action/ActionDatalegis.php?>

acao=abrirTextoAto&tipo=RDC&numeroAto=00000657&seqAto=000&valorAno=2022&orgao=RDC/DC/ANVISA/MS. Acesso em: 10 jun. 2026.

AUTORIDADE NACIONAL DE PROTEÇÃO DE DADOS (ANPD). Radar tecnológico: inteligência artificial generativa. Brasília, DF: ANPD, 2024. Disponível em: https://www.gov.br/anpd/pt-br/documentos-e-publicacoes/documentos-de-publicacoes/radar_tecnologico_ia_generativa_anpd.pdf. Acesso em: 10 jun. 2026.

BRASIL. Lei nº 13.709, de 14 de agosto de 2018. Lei Geral de Proteção de Dados Pessoais (LGPD). Brasília, DF: Presidência da República, 2018. Disponível em: https://www.planalto.gov.br/ccivil_03/_ato2015-2018/2018/lei/l13709.htm. Acesso em: 10 jun. 2026.

LEE, G.; HWANG, H.; BAE, S.; KWON, Y.; SHIN, W.; YANG, S.; SEO, M.; KIM, J.-Y.; CHOI, E. EHRSQL: a practical text-to-SQL benchmark for electronic health records. In: Advances in Neural Information Processing Systems (NeurIPS) – Datasets and Benchmarks Track, 2022. Disponível em: <https://arxiv.org/abs/2301.07695>. Acesso em: 10 jun. 2026.

LI, J.; HUI, B.; QU, G. et al. Can LLM already serve as a database interface? A big bench for large-scale database grounded text-to-SQLs (BIRD). In: Advances in Neural Information Processing Systems (NeurIPS) – Datasets and Benchmarks Track, 2023. Disponível em: <https://arxiv.org/abs/2305.03111>. Acesso em: 10 jun. 2026.

NATIONAL INSTITUTE OF STANDARDS AND TECHNOLOGY (NIST). Artificial Intelligence Risk Management Framework (AI RMF 1.0). NIST AI 100-1. Gaithersburg, MD: NIST, 2023. Disponível em: <https://nvlpubs.nist.gov/nistpubs/ai/nist.ai.100-1.pdf>. Acesso em: 10 jun. 2026.

OWASP. OWASP Top 10 for Large Language Model Applications. [S. l.]: OWASP Foundation, 2023. Disponível em: <https://owasp.org/www-project-top-10-for-large-language-model-applications/>. Acesso em: 10 jun. 2026.

REBEDEA, T.; DINU, R.; SREEDHAR, M. N.; PARISIEN, C.; COHEN, J. NeMo Guardrails: a toolkit for controllable and safe LLM applications with programmable rails. In: Proceedings of the 2023 Conference on Empirical Methods in Natural Language Processing (EMNLP): System Demonstrations, p.

431-445, 2023. Disponível em: <https://arxiv.org/abs/2310.10501>. Acesso em: 10 jun. 2026.

SHI, L.; TANG, Z.; ZHANG, N.; ZHANG, X.; YANG, Z. A survey on employing large language models for text-to-SQL tasks. *ACM Computing Surveys*, 2024. Disponível em: <https://arxiv.org/abs/2407.15186>. Acesso em: 10 jun. 2026.

SWEENEY, L. k-anonymity: a model for protecting privacy. *International Journal of Uncertainty, Fuzziness and Knowledge-Based Systems*, v. 10, n. 5, p. 557-570, 2002. DOI: 10.1142/S0218488502001648. Disponível em: <https://doi.org/10.1142/S0218488502001648>. Acesso em: 10 jun. 2026.

WORLD HEALTH ORGANIZATION (WHO). Ethics and governance of artificial intelligence for health: guidance on large multi-modal models. Geneva: WHO, 2024. Disponível em: <https://www.who.int/publications/b/70584>. Acesso em: 10 jun. 2026.

YU, T.; ZHANG, R.; YANG, K.; YASUNAGA, M.; WANG, D.; LI, Z.; MA, J.; LI, I.; YAO, Q.; ROMAN, S.; ZHANG, Z.; RADEV, D. Spider: a large-scale human-labeled dataset for complex and cross-domain semantic parsing and text-to-SQL task. In: *Proceedings of the 2018 Conference on Empirical Methods in Natural Language Processing (EMNLP)*, 2018. Disponível em: <https://arxiv.org/abs/1809.08887>. Acesso em: 10 jun. 2026.

Apêndice A — Arquitetura de referência em quatro camadas

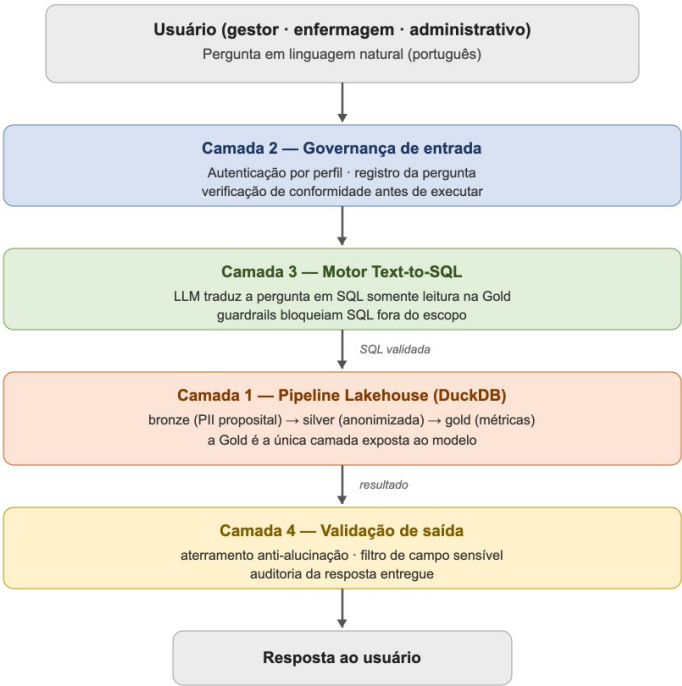


Figura A.1. Fluxo de uma pergunta pelas quatro camadas. Fonte: o autor.

Camada	Responsabilidade	Documentação
1. Pipeline Lakehouse	Ingestão (Bronze), limpeza e anonimização (Silver), métricas (Gold)	camadas/01
2. Governança de entrada	Perfil, registro da pergunta e conformidade antes de executar	camadas/02
3. Motor Text-to-SQL	Pergunta em português para SQL somente leitura na Gold	camadas/03
4. Validação de saída	Aterramento, filtro de campo sensível e auditoria da resposta	camadas/04

Quadro A.1. Síntese das quatro camadas. Fonte: o autor.

Apêndice B — Requisitos regulatórios e controles

Requisito	Controle na arquitetura	Camada
REG-LGPD-001	Anonimização na Silver: remoção de nome, CPF e data de nascimento; derivação de faixa etária	Silver
REG-LGPD-002	Pseudonimização de id_paciente por hash; nenhuma identificação direta sobrevive à Silver	Silver
REG-LGPD-003	Apenas a Gold, agregada, é exposta ao motor; Bronze e Silver inacessíveis (CTRL-GOV-004)	Gold
REG-LGPD-004	Perfis autorizam apenas tabelas Gold específicas (CTRL-GOV-005)	Entrada
REG-LGPD-005	Guardrails CTRL-GOV-001 a 003 e 006: SQL única somente leitura, sem escrita/admin, conexão read-only	Entrada
REG-LGPD-006	Filtro de saída CTRL-VALID-002: bloqueia coluna com nome de campo sensível	Saída
REG-LGPD-007	Auditoria CTRL-AUD-001: registro de toda pergunta e resposta	Auditoria
REG-ANPD-001	Aterramento CTRL-VALID-001: toda tabela citada deve existir no schema Gold conhecido	Saída
REG-ANPD-002	Escopo restrito por perfil, execução somente leitura e registro integral	Entrada e Auditoria
REG-ANVISA-001	Guardrails versionados, auditoria e reprodutibilidade do software	Transversal
REG-PESQ-001	Determinismo (SEED, SIM_TODAY); separação motor LLM (números) vs oráculo (autoteste)	Transversal

Quadro B.1. Mapeamento de requisitos regulatórios para controles e camadas. Fonte: o autor.